

Use case using HTTP-upstream authN/authZ-attribute-supply

Swithun Crowe
University of St Andrews
cs2@st-andrews.ac.uk

November 15, 2011

Abstract

Use case describing how Fedora would obtain authentication credentials from an upstream authentication/authorization attribute supplier, such as a single sign on (SSO) system.

1 Goal

Many institutions use single sign on (SSO) systems such as Shibboleth or CAS, or have authentication methods other than those supported by JAAS. Many of these systems will add attributes in HTTP headers to indicate that a user has authenticated.

The goal is to enable Fedora to access authNZ attributes provided by such an upstream attribute supplier. The attributes would indicate that the user has successfully authenticated, and the attributes would be used to authorize access to objects.

As with LDAP authN, this would reduce the need to Fedora to maintain its own lists of user credentials, allow Fedora to use institution-wide information, such as user groups and roles, and also allow users to perform authN with their institutional credentials.

A servlet filter would intercept the request for a resource, and look for authNZ information. This would be put into request attributes, and passed on down the filter chain, for use by other filters which handle authZ, e.g. the PEP filter. The particular pieces of information would be configurable, as different institutions and different SSO systems have different ways of passing on authNZ information, e.g. via application-specific HTTP headers or cookies.

2 Actors

The principal actors in such a scenario would be a Fedora repository, an upstream authentication system, and users of both systems.

3 Preconditions

It is assumed that there will be a working SSO system in place already, which authenticates users and passes on authorization information. Also, Fedora should have XACML authZ enabled.

4 Success

When the system as proposed is working, users may authenticate using the upstream authN system. If they try and fail, or don't try, they can still access parts of Fedora which do not require authN. If they succeed in authenticating upstream, then the servlet filter will extract the attributes related to their authentication (e.g. user name and role/s in Fedora), and use these for authZ.

Depending on whether the user is authorized to access objects (based on their user name or their role/s in Fedora) or not, they will either be given access to the objects, or be informed that access is forbidden.

5 Sub-variations

Some Fedora sites may find that an upstream authN filter is all they need. Other sites may have no use for it at all. And many sites will want to use both this filter and the FeSL/JAAS filter.

Relying solely on an upstream filter means that programmatical authenticated access to Fedora (e.g. by the command line admin utilities or by GSearch or other users of the REST API) may not be possible.

In cases where both filters are to be used (i.e. where most users will perform authN upstream, but programmatical access is still needed), the filters should be ordered in the chain, so that the upstream filter has the first go at extracting authNZ attributes. If it succeeds, then the JAAS filter will not attempt to force authN. If it fails, then the JAAS filter will force authN. Thus, users who wish to use upstream authN must do so before going to the Fedora site.

6 Open

It isn't clear whether Fedora should try to handle caching (of users' authNZ information) issues, or simply rely on the upstream SSO for that. Performance may be improved with caching, but this may open security problems and introduce extra dependencies and complexity.